

CRAFT Certificate Enrollment and Tickets

Certificate Request Agent for Tickets | Process Overview

CRAFT lets an approved user obtain Kerberos credentials noninteractively from a trusted, administrator-managed Linux endpoint, including a host that is not domain-joined. Unattended scripts and applications can then access Active Directory resources as that user without collecting, storing, or replaying the user's AD password. CRAFT authenticates through a short-lived certificate and saves a ticket-granting ticket (TGT); the user certificate and key are temporary, while the ticket cache remains after CRAFT exits.

Enrollment and Authentication

An administrator first configures directory access, the certificate authority (CA), the Certificate Enrollment Web Service (CES), trust settings, and the users permitted to enroll. Configuration ships disabled. Once enabled, a user invokes `craft` with no arguments; the following steps run for that user.

Stage	What Happens
1 Identify the caller	CRAFT checks the actual Linux account and home directory. Only approved <code>craft-users</code> members may launch it; users cannot name another person to enroll.
2 Resolve AD identity	The service account queries Active Directory for the matching username and user principal name (UPN). Missing or ambiguous accounts are rejected.
3 Request a certificate	CRAFT generates a new private key and an enrollment request. The enrollment agent signs the request on behalf of the identified user; CES submits it to the CA.
4 Validate the result	The CA issues the user certificate. CRAFT checks the key, UPN, template, permitted uses, lifetime, trust chain, and revocation information.
5 Obtain a ticket	CRAFT authenticates with the certificate and private key using PKINIT. The domain controller decides the ticket lifetime; CRAFT checks the returned identity, flags, times, and encryption.
6 Publish the cache	After validation succeeds, CRAFT replaces <code>.krb5cc_craft</code> in the caller's home and prints its FILE cache name. The cache is accessible only to its owner under normal file permissions.

Use the Cache to Access AD Resources

After enrollment and authentication, the user selects the resulting credential cache for an application, typically through `KRB5CCNAME`. The Kerberos library uses the cached ticket-granting ticket (TGT) to request service tickets from the domain controller for the target services. Those tickets let the application authenticate as the user to resources such as SMB file shares, LDAP directories, and Kerberos-enabled web services, where supported and configured. Access remains subject to the user's permissions and the service's policy; obtaining a ticket does not grant additional access rights.

Identity and Trust

CRAFT checks the certificate UPN against the directory lookup. The CA supplies the SID for domain-controller mapping. Changing the requested common name (CN) does not change the approved identity. Directory and CES credentials belong to the service account; the published ticket belongs to the user. CA-side restrictions must limit enrollment to the intended template and recipient group. [1, 2]

This administrator-authorized certificate path supports automation without retaining a user's password alongside an MFA-protected interactive sign-in. CRAFT does not perform an MFA challenge or prove that the user completed one. Its trust rests on the managed host, enrollment credentials, and CA restrictions.

Certificate Storage and Cleanup

The Issued User Certificate and Private Key

Each enrollment attempt generates a fresh user private key. The issued certificate and key are held in process memory. For the Kerberos authentication step, CRAFT exposes temporary, memory-backed files to the Kerberos library. These have no persistent pathname in the user's home, `/etc/craft`, `/run/craft`, or a temporary directory.

The temporary memory files close when the authentication operation ends, and the worker releases its certificate and key when it exits, on success or failure. CRAFT does not install the issued certificate in a certificate store, export a PEM or PFX file for the user, or keep the key for a later run. The private key is generated locally and is not submitted to the CA.

What Remains on the Linux Host

The persistent user credential is `.krb5cc_craft` in the caller's actual home directory. This file contains the Kerberos TGT and session key, not the issued certificate or its private key. Applications use this cache to request service tickets. It is owned by the caller with mode 0600 and remains until replaced or removed; CRAFT does not delete it automatically when its tickets expire.

Administrator-provisioned enrollment-agent and transport credentials remain in `/etc/craft`, along with configuration, trust anchors, and revocation lists. These are distinct from the temporary user certificate. `/run/craft` holds per-user lock and timing information for enrollment attempts, not a retained user certificate or key.

What the Certificate Authority Retains

Client cleanup does not erase the CA's copy of an issued certificate or its enrollment and audit records. A failed or interrupted run can still leave an issued certificate recorded at the CA. CRAFT does not automatically revoke that certificate or cancel the request. Administrators manage CA retention, audit review, and any required revocation.

What Ephemeral Means Here

The user certificate and key are ephemeral client credentials, but this is not a guarantee that no trace can reach storage. Operating-system swap and host memory capture may expose memory contents, and a privileged host administrator can inspect credentials. Protect the host and its swap policy accordingly. Losing the temporary key does not invalidate an already-issued Kerberos ticket; protect the persistent ticket cache separately.

Ticket Lifetimes and Everyday Use

Three Separate Lifetime Limits

The default certificate acceptance cap is 36,000 seconds (10 hours) of total validity, including any CA backdating. The CA must issue that profile; CRAFT does not set or shorten certificate dates. The certificate must also be currently valid and pass the configured trust and revocation checks.

CRAFT requests a 10-hour initial TGT and a 7-day renewal window. A renewal window is the period during which an eligible ticket can be renewed, not seven days of uninterrupted ticket validity. The domain controller controls the actual grant, and PKINIT can constrain the initial ticket by the certificate/key lifetime. [3, 4]

By default, `require_full_tgt_lifetime=yes` rejects a shortened initial grant or renewal window without replacing the existing cache. An administrator may set `require_full_tgt_lifetime=no` to accept shorter grants with a warning. CRAFT never rewrites the domain controller's ticket times.

Select the Cache and Use Applications

Run CRAFT as the intended user, without `sudo`. Select its returned cache in the current shell, then inspect the ticket:

```
cache=$(/usr/local/bin/craft) && export KRB5CCNAME="$cache" && \
  klist -ef -c "$KRB5CCNAME"
```

Kerberos-aware applications launched from that shell can use the cache. CRAFT cannot change its parent shell's environment. The optional `with-craft` wrapper can run a command with a newly obtained cache already selected.

Renewal and Failed Attempts

Use `kinit -R -c "$KRB5CCNAME"` for manual renewal or `craft-maintain` for automatic maintenance. Renewals need only the cache; fresh authentication requires a new certificate.

Enrollment, validation, or authentication failures leave the existing cache in place. Only a successful run replaces it. Review errors and CA/domain-controller logs before retrying; attempts are rate-limited per user. Validate the installed deployment in a lab and follow the configuration guide for acceptance checks.

Long Running Jobs

Start once as the approved batch user; it returns when credentials and detached maintenance are ready. No job wrapper or cron is needed.

```
job_pid=$$
cache=$(/usr/local/bin/craft-maintain --watch-pid "$job_pid") || exit "$?"
export KRB5CCNAME="$cache"
```

craft-maintain renews TGTs without certificates and reenrolls near the absolute renewal deadline. Ten-hour/seven-day grants normally renew at eight hours and reenroll around day six; actual grants set the schedule.

Use --max-duration 21d to add a cutoff. Maintenance stops with the watched PID; keep the shell alive, exec the job, or watch its controller. Jobs for one user share cache updates; stopping maintenance leaves the cache intact.

```
/usr/local/bin/craft-maintain --status --watch-pid "$job_pid"
klist -ef -c "$KRB5CCNAME"
```

Refresh failures preserve the cache and retry; failed enrollments share a cooldown from one minute to one hour. Check status and AUTHPRIV logs for errors. Later failures do not stop the job; applications must reload refreshed credentials when authenticating again.

Install craft-maintain without setuid/setgid. Renewal requires Linux 5.3+, /proc and system /etc/krb5.conf matching the enrollment realm/KDC. The scheduler must retain background processes and allow later setuid craft calls. See source/README.md for setup and status.

Primary References

- [1] [Microsoft MS-WCCE: enrollment-on-behalf-of CMS requests](#)
- [2] [Microsoft MS-WCCE: CA certificate SID security extension](#)
- [3] [RFC 4556, sections 3.2.2–3.2.3: client certificate usage and ticket/key lifetime](#)
- [4] [Microsoft: Maximum lifetime for user ticket \(hours\)](#)

License

CRAFT source code, scripts, configuration examples, and documentation are licensed under the GNU General Public License, version 3 (SPDX: GPL-3.0-only). See the repository LICENSE file or <https://www.gnu.org/licenses/gpl-3.0.html> for the full terms. This material is provided without warranty, as described in the license.